

LAWS & REGULATIONS

1. Protecția Datelor și GDPR

- **Date personale:** orice informație care poate identifica direct sau indirect o persoană (ex: nume, CNP, IP, amprente).
- **Principiile GDPR:**
 - *Legalitate, echitate și transparență:* datele trebuie procesate în mod legal și transparent.
 - *Limitarea scopului:* colectarea și utilizarea doar pentru scopurile declarate.
 - *Minimizarea datelor:* colectarea doar a datelor necesare.
 - *Exactitate:* datele trebuie să fie corecte și actualizate.
 - *Limitarea stocării:* păstrarea datelor doar cât timp este necesar.
 - *Integritate și confidențialitate:* protecția datelor împotriva accesului neautorizat.
- **Drepturile persoanelor conform GDPR:**
 - Dreptul de acces
 - Dreptul la rectificare
 - Dreptul la ștergere („dreptul de a fi uitat”)
 - Dreptul la restricționarea prelucrării
 - Dreptul la portabilitatea datelor
 - Dreptul de opoziție la prelucrare
 - Dreptul de a nu face obiectul unei decizii automate (ex: profilare)
- **Roluri GDPR:**
 - *Operator de date (Data Controller):* decide scopul și mijloacele procesării datelor (ex: bancă, companie).
 - *Persoana împuternicită (Data Processor):* procesează datele în numele operatorului (ex: firmă de cloud storage).
 - *Autoritate de Supraveghere:* monitorizează respectarea GDPR.

2. Drepturi de Autor și Licențiere Software

- **Ce protejează drepturile de autor în software?**
 - Codul sursă, codul obiect, documentația
 - *Nu protejează:* idei, concepte, funcționalități
- **Tipuri de licențe open-source:**
 - *Permissive (ex: MIT, Apache):* permit reutilizarea și modificarea fără multe restricții.
 - *Copyleft (ex: GPL):* orice software derivat trebuie să fie distribuit sub aceeași licență.
 - *Weak Copyleft (ex: LGPL):* codul modificat trebuie să fie sub aceeași licență, dar poate fi integrat în software proprietar.

3. Confidențialitatea Datelor și NDA (Non-Disclosure Agreement)

- Un NDA definește ce informații sunt confidențiale, cine are acces la ele și pentru ce scop.
- *Nu există o definiție unică a informațiilor confidențiale în lege, ci acestea trebuie specificate în contract.*

4. Securitatea Datelor și Principiile de Acces

- **Principiul *Need to Know*:** accesul la date este permis doar celor care au nevoie.
- **Principiul *Least Privilege*:** fiecare utilizator primește doar minimul de permisiuni necesare.
- **Autentificare și parole:**
 - Parolele trebuie să fie unice, complexe și schimbate periodic.
 - Nu se folosesc parole implicite (ex: admin/admin).
- **Pseudo-anonimizare vs. Anonimizare:**
 - *Pseudo-anonimizare:* datele pot fi identificate indirect (ex: criptarea datelor, hashing).
 - *Anonimizare:* datele nu mai pot fi legate de o persoană (ex: eliminarea atributelor unice).

5. Responsabilitatea în cazul încălcării securității

- Operatorul de date este responsabil dacă nu face audituri sau nu verifică procesatorii.
- Furnizorii de software pot fi responsabili dacă:
 - Nu au implementat măsuri de securitate cerute.
 - Nu au remediat vulnerabilități cunoscute.
 - Software-ul este vulnerabil la atacuri de bază (ex: SQL injection).

6. Transferul Datelor Personale

- Transferul datelor între companii trebuie să aibă un temei legal (ex: consimțământ, contract).
- Transferurile internaționale trebuie să respecte standarde (ex: SCC - Standard Contractual Clauses).

AUDIT

1. Audit Objectives and Scope

- **Audit Objectives:** The goal of an IS audit is to ensure that the information systems are secure, effective, and aligned with the organization's objectives. This includes reviewing the design and implementation of controls and assessing their operational effectiveness.
- **Audit Scope:** Defines the boundaries of the audit. This includes determining what areas will be reviewed (e.g., systems, processes, compliance) and what will be excluded. The scope should align with the audit objectives.

2. Audit Planning

- **Risk Assessment:** The planning phase of an audit starts with risk assessment, which identifies the most critical areas and resources that need attention based on the organization's risk profile.
- **Data Collection:** Based on the audit scope and objectives, the auditor will determine the necessary data to collect. The complexity of the organization, the prior year's findings, and audit objectives are key considerations in this step.
- **Audit Program:** A detailed plan outlining the audit procedures that will be followed to assess controls and systems. This includes specifying tasks, timelines, and responsibilities.

3. Audit Evidence

- **Types of Evidence:** Auditors collect evidence to support their findings. The reliability of evidence varies; for example:
 - **External evidence** (e.g., confirmation letters from third parties) is considered highly reliable.
 - **Internal evidence** (e.g., reports generated within the organization) is often less reliable but can still be useful.
 - **Documentary evidence** (e.g., logs, reports, emails) supports conclusions drawn from audit tests.
- **Sufficient and Appropriate Evidence:** The audit report must be backed by enough valid evidence to justify the auditor's conclusions.

4. Audit Techniques

- **Tests of Control:** These tests are used to evaluate the effectiveness of the organization's controls. They include procedures like:
 - **Inquiry:** Asking management or personnel about processes or controls.
 - **Inspection:** Reviewing documentation or system logs.
 - **Observation:** Watching processes or controls being performed in real-time.
 - **Reperformance:** Repeating a procedure or calculation to check accuracy.
- **Substantive Testing:** This involves testing the transactions and activities in detail to determine if the control procedures are working effectively.

5. Audit Findings

- **Finding Documentation:** Any issues identified during the audit must be documented with clear evidence supporting the conclusion.
- **Report Writing:** The findings must be summarized in an audit report, which should be:
 - Objective and clear.
 - Based on sufficient and appropriate evidence.
 - Aligned with the audit scope and objectives.
 - Providing actionable recommendations for improving controls or mitigating risks.

6. Audit Reporting

- **Audit Report Structure:** Typically includes:
 - **Introduction:** Background information, scope, and objectives.
 - **Methodology:** The techniques used to gather evidence.
 - **Findings:** Description of issues or deficiencies found.
 - **Conclusion:** A summary of overall audit results.
 - **Recommendations:** Suggestions for corrective actions or improvements.
- **Review and Approval:** Audit reports are reviewed by senior management and may need approval before being shared externally.

7. Control Types

- **Preventive Controls:** Designed to prevent undesirable events before they happen (e.g., access controls, encryption).
- **Detective Controls:** Designed to identify issues after they occur (e.g., audit logs, intrusion detection systems).
- **Corrective Controls:** Designed to correct problems after they are detected (e.g., backup restoration procedures).
- **Compensating Controls:** Alternative measures put in place when primary controls are not feasible.

8. Audit Risks

- **Inherent Risk:** The risk of a control failure due to the nature of the business or system, regardless of controls in place.
- **Control Risk:** The risk that the organization's internal controls will not prevent or detect a material misstatement or issue.
- **Detection Risk:** The risk that the audit procedures will not detect a material issue.

9. Post-Audit Activities

- **Follow-up Audits:** Ensuring that the management has taken appropriate actions on the findings and recommendations from the audit. This involves revisiting the areas where weaknesses were identified and checking if corrective actions were implemented.
- **Post-Incident Review:** This is crucial after a security incident. It helps assess the effectiveness of response measures, improve internal controls, and update incident response plans.

10. Key Concepts for IS Auditors

- **Independence:** IS auditors must remain independent from the areas they audit to provide objective assessments.
- **Confidentiality:** Auditors must protect the confidentiality of all information gathered during the audit.
- **Objectivity:** The auditor's work should be based on facts, not influenced by personal biases or external pressures.

11. Common Auditing Frameworks and Standards

- **ISACA's COBIT (Control Objectives for Information and Related Technologies):** Provides a framework for IT governance and management, which auditors use to assess IT controls and risk management.
- **ITIL (Information Technology Infrastructure Library):** A set of best practices for IT service management that auditors may reference.
- **ISO/IEC 27001:** An international standard for information security management systems that outlines requirements for a robust security framework.

12. Audit Tools

- **Automated Tools:** Many IS auditors use automated tools to conduct vulnerability assessments, penetration testing, and log analysis. These tools help efficiently identify risks and inefficiencies.
- **Audit Software:** Specialized software helps auditors gather and analyze data, track findings, and prepare reports.